

Phishing Awareness Simulation

Using Social Engineering Techniques

Introduction

Most people know phishing is a thing. Most people also think they would recognize one. The data says otherwise — phishing is still the leading cause of data breaches, and it works because the emails have gotten genuinely convincing. This project ran a controlled simulation to see exactly how many people would fall for a realistic phishing attempt, understand why, and figure out what actually changes behavior rather than just raising awareness.

Every participant was told in advance that a simulation would be running and gave written consent. No real credentials were captured. No systems were accessed without permission. This was purely educational.

Methodology

Understanding how phishing works

Before designing anything, a set of real phishing emails were studied to identify the psychological tactics that make them effective. Three patterns came up repeatedly: urgency ('act now or lose access'), authority ('this is from your IT team'), and fear of missing out ('your bonus is waiting'). The simulation was built around urgency because it tends to short-circuit careful thinking most effectively.

The simulation email

A fake password reset email was written in plain, professional language — no dramatic warnings, no obvious red flags. It told recipients that their account would be locked in 24 hours unless they reset their password, and included a button linking to a demo login page. The email was designed to look like a routine internal IT message.

The landing page

A simple login page was built in HTML and CSS to mimic a corporate portal. When someone submitted the form, instead of capturing anything, they were taken straight to an educational page explaining that this was a simulation, showing them exactly which warning signs they had missed, and giving them tips for spotting real phishing attempts.

The test group

The email was sent to 20 classmates who had signed consent forms. Four behaviors were tracked: whether they opened the email, whether they clicked the link, whether they tried to enter credentials, and whether they reported it as suspicious.

Results

What happened	Out of 20	Rate
Opened the email	18	90%
Clicked the phishing link	11	55%
Tried to enter credentials	7	35%
Reported it as suspicious	4	20%
Spotted it without taking any action	5	25%

More than half the group clicked the link. Over a third tried to enter their credentials. Only one in five reported it. These numbers are uncomfortable, but they are consistent with real-world phishing benchmarks — which makes the simulation a valid test.

Lessons Learned

Urgency works

The 24-hour deadline was the main reason people clicked without thinking. The participants who did not fall for it almost all said the same thing: the urgency felt off compared to how their IT team normally communicates. That pattern recognition is exactly what training should build.

Appearance matters more than content

Several people said they checked whether the email looked right but did not check the sender address or hover over the link. A convincing visual design bypassed the content check entirely. This is why well-designed phishing emails are so dangerous.

Knowing the risk is not the same as being safe

Everyone in the test group knew what phishing was. 55% still clicked. Awareness raises the bar slightly, but it does not reliably change behavior on its own. Repeated practice through simulations is what actually builds the instinct to pause.

People do not know whether to report things

Most people who did not report the email were not sure if reporting was the right move, or worried about looking foolish for being unsure. A blame-free, clearly communicated reporting process needs to be actively built — it does not appear on its own.

What Actually Prevents Phishing

On the technical side

- Email filtering that uses AI to catch phishing before it reaches the inbox.
- DMARC, DKIM, and SPF records configured correctly so attackers cannot fake your domain.
- Link sandboxing — URLs get scanned before the browser loads them.
- MFA on every account, so a stolen password alone gets an attacker nowhere.

On the human side

- Regular phishing simulations — monthly is ideal — not as a trap but as practice.
- Immediate educational feedback when someone clicks, while the experience is fresh.
- A simple, blame-free way for anyone to flag a suspicious email.
- Training staff to verify unusual requests through a separate channel — call the person, do not reply to the email.

As policy

- A clear rule that IT will never ask for passwords by email — and everyone knows it.
 - Rewarding people who report suspicious emails, not just people who avoid clicking.
 - Including phishing awareness as part of onboarding for every new person who joins.
-

Deliverables

- Phishing simulation email template with annotations on the social engineering tactics used
- HTML demo login page with educational redirect on form submission
- Results table with full participant behavior breakdown
- Consent form template used for the test group
- Analysis of lessons learned and countermeasures